技术文档

让金融意图有依据，让每次执行有边界

AI-Banking 以自然语言查询和受控代办连接账单分析、订阅管理与内部转账。模型负责理解和提出工具意图，应用负责身份、授权与任务约束，模拟银行执行器在事务中确认资金事实。本文给出已实现架构、核心规则、交互闭环与验证依据。

版本	说明
编制日期	2026-10-30（Asia/Shanghai）
交付状态	评审稿 v1.1；基于本地未提交工作树，不代表正式提交完成
代码基线	2b63eba；分支 codex/payees-transfer-workflow
适用范围	虚构账户、资金与联系人；Windows 本地单机单进程演示
证据边界	222项自动化已通过；列示人工用例已由项目负责人审核通过

阅读导引

02 产品范围与用户路径 · 03 Agent运行与安全关卡 · 04 问题-工具映射与压缩 · 05 账单算法 · 06 订阅识别 · 07 转账与授权 · 08 固定联动 · 09 安全与运行 · 10 验证和限制

02 / 产品范围与用户路径

目标是让用户先看清数据与对象，再决定是否执行。查询结果、分析线索、方案预览、资金批准与实际回执分别呈现，避免把“建议”当成“已执行”。

场景	已实现	边界
账单分析	区间汇总、分类与商户统计、前期对比、异常线索、分页证据	前期为相同天数，不固定为上月；异常不是欺诈判断
订阅管理	周期支出线索、证据复核、显式登记、受控取消	登记不扣款；取消不退款；没有后台自动扣费
智能转账	已登记对象、备注/尾号搜索、人工确认、明确预授权	模拟银行内部CNY转账，不查真实手机号或好友
跨场景联动	先取消用户选择的订阅，再转用户指定的固定金额	固定流程；未来少支出不是当前到账资金
理财与卡片	模拟目录与脱敏信息查询	没有申购赎回、挂失、调额等写能力

典型路径

查看完整账单 → 核对周期支出原流水 → 显式登记需管理的订阅 → 确定收款人 → 预览取消与转账影响 → 保存方案 → 每步独立确认 → 核对后端回执。

数据与实现形态

原生 HTML/CSS/JavaScript，FastAPI/Pydantic，Python 3.12+，SQLite。页面和API同源，服务端保存会话与对话。全部账户与资金为虚构；新建用户会初始化相互隔离的模拟数据。

实现与用法依据：README.md；docs/billing-insights.md；docs/transfer-workflows.md。

03 / Agent运行链路与安全检查

系统采用一个主Agent，通过类型化工具查询或准备业务。图中A-D均为确定性的应用检查，没有额外的“安全审核模型”。用户身份与执行策略由服务端绑定。

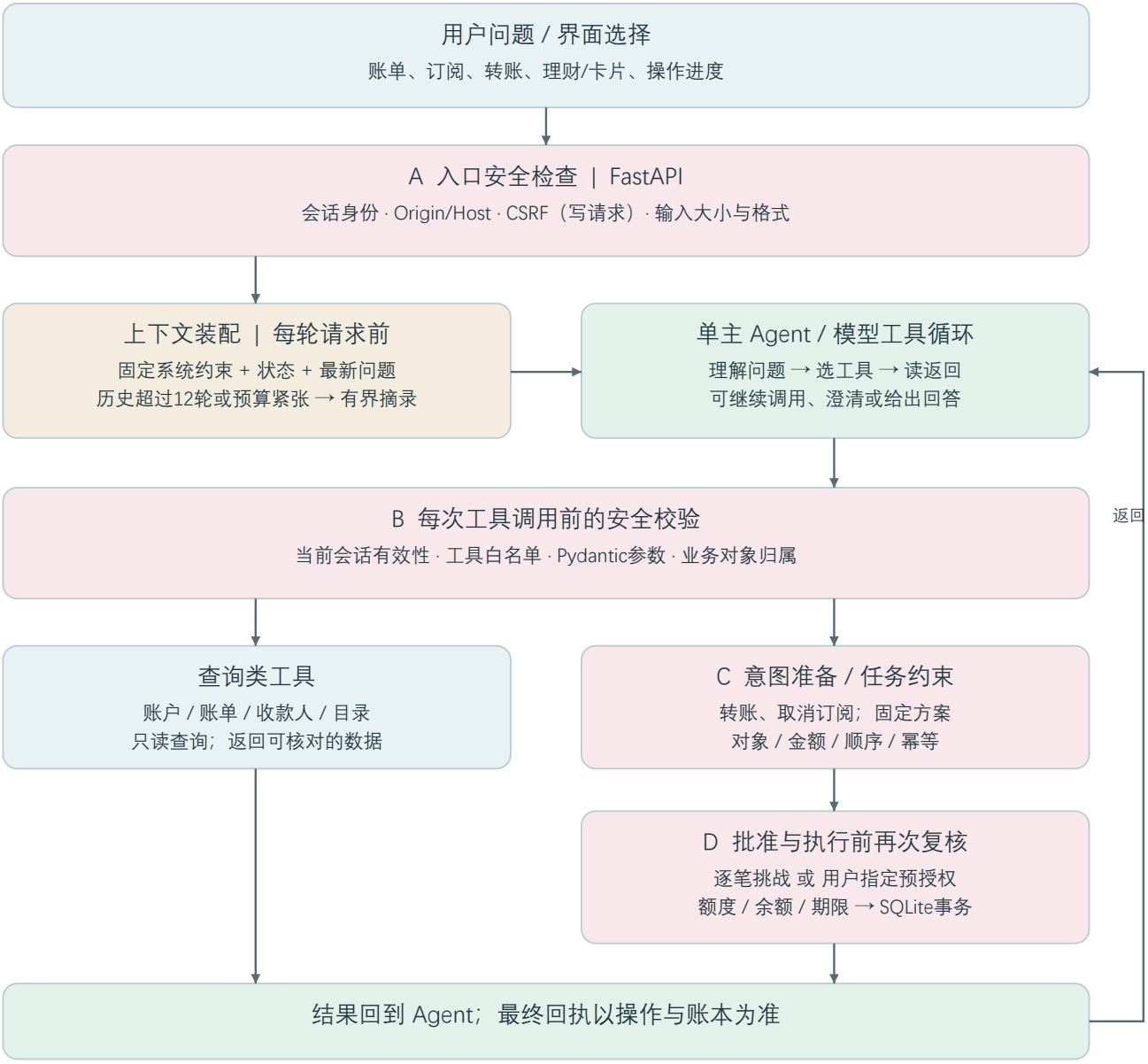
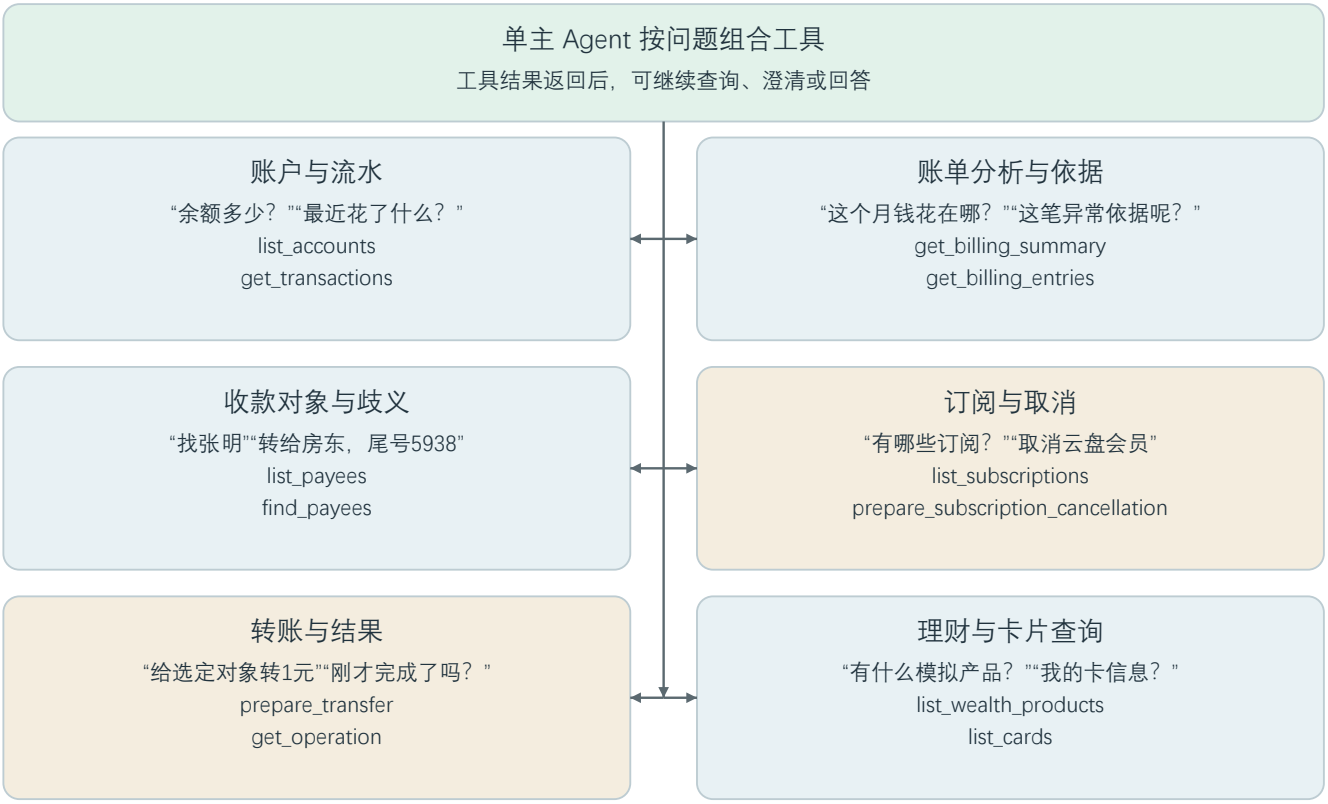


图1 从用户问题到工具返回的完整路径。查询直接返回数据；意图必须经过任务约束及独立批准/预授权，再由银行事务执行。

A在请求入口；B在每次Agent.tool调用前并校验Schema；C在AgentOperations.prepare和Bank.prepare；D在人工decide或预授权路径，以及Bank.execute事务内。任何环节拒绝都不会被模型文字绕过。

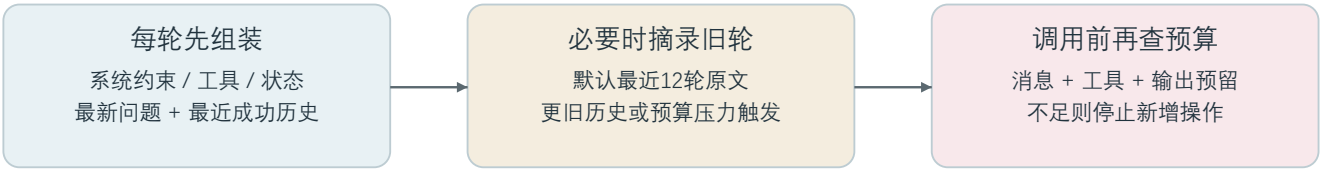
依据：app.py；agent.py 的tool/dispatch/model_answer；agent_operations.py 的prepare；banking/service.py 的prepare/decide/execute。原系统模块图和Archify源仍随包保留。

04 / 问题类型、工具与上下文压缩



上述是职责映射，模型可跨类组合工具，不是硬编码分类器。查询类工具不付款；两个prepare工具在人工模式下等待批准，在明确预授权模式下可经复核执行。get_operation用于核查两类操作的原状态。

什么时候压缩?



不是每隔N轮定时压缩；工具循环中超预算会停写，不继续冒险执行。

默认：32000估算tokens · 摘要800 · 输出1500 · 工具预留4000

每个新问题先装配上下文。默认成功历史超过12轮时，更早回合作有界摘录；历史恰好12轮且预算充足时不因计数压缩。若已有13轮成功历史，下一次请求会摘录较早回合；长消息导致预算紧张时也可更早压缩。

预算不足时逐步将近期旧轮移入摘录，再缩小摘要；固定信息仍放不下则报CONTEXT_BUDGET_EXCEEDED并暂停新增操作。工具循环每次模型请求前再核预算，过大返回另有6000字符截断。

最多读取60个成功回合，默认旧问/答摘录80/140字符；每轮最多8次模型请求、每次4个工具调用、整轮90秒。token为启发式估算，压缩不是无损记忆。依据：context.py、config.py、agent.py。

05 / 账单分析与异常线索

统计区间以Asia/Shanghai自然日为准。界面结束日期含当天，API采用[start,end)；前期为[start-(end-start),start)，两期在同一数据库事务内读取。消费、退款和转账分别计算，分类回查不截断为最近30笔。

规则	判定与用途
固定大额线索	单笔非转账支出 ⩾ 100000分（1000元），提示人工核对
相对历史线索	前期同类至少3笔，取median_low；本期单笔 ⩾ 10000分且严格大于其3倍
证据分页	按原区间与归属分页读取，页大小1-50；金额均为整数分



图2 合成流水：200元餐饮相对前期20元中位数触发线索。非欺诈判断或真实模型评测。 局部放大排版，原始完整PNG随素材包附送。

median_low在偶数样本时取较低中位数，不是均值。线索不触发自动止付，不证明欺诈；模型解释也不能改写原流水。依据：banking/reports.py；tests/test_insights.py。

06 / 订阅线索与显式登记

按本人账户与商户分组最近一年的支出。候选须至少3笔、金额完全相同、相邻日期间隔均在25-35天、最近45天有扣费。已登记的同账户同商户不再建议，包括已取消记录。

界面展示原流水、规则和证据摘要；用户明确勾选确认后，事务内重新识别并比对摘要。证据改变则拒绝，并发或重复确认只登记一次。下次日期按最近日期加一个日历月估计，月末裁齐。



图3 三笔9.90元周期支出证据与登记确认。独立虚构数据、脚本化演示；处于待确认，不扣款。 局部放大排版，原始完整PNG随素材包附送。

副作用边界

规则只发现周期性支出，不证明用户仍有自动续费合约或订阅闲置。登记不授予权限、不产生扣款；后续取消仍走原独立确认或明确预授权，不退款，也不模拟真实商户解约接口。

依据：banking/subscriptions.py；tests/test_insights.py。

07 / 智能转账与权限复核

收款人搜索采用NFKC规范化后的名称、备注和尾号包含匹配；返回唯一、需澄清或未找到。两位“张明”分别以同事4712、房东5938区分。联系人由密码复核后显式载入，独立账户可收模拟款但不能登录，也不暴露对方余额。

人工确认挑战绑定会话、原操作与参数摘要，要求明确批准；关闭弹窗不执行。预授权需先密码复核并明确选择账户、对象、操作、金额、期限和最低余额，再在当前对话选用；每次执行仍复核。



图4 后端1元转账确认单，尾号、备注、费用和余额预览。脚本化Agent，不是实时模型能力证明。 局部放大排版，原始完整PNG随素材包附送。

整数分、CNY、模拟手续费0；扣款、入账、双边账本与成功状态在同一事务提交。任务/步骤/参数绑定支持幂等，结果未知按原编号核对，不换编号重发。依据：banking/service.py、contacts.py。

08 / 固定联动方案与恢复

用户选择1-5项登记订阅、付款账户、收款人和固定金额，后端给出步骤与资金影响。预览摘要绑定余额、备注、订阅金额/日期/状态；变化后必须重新核对。创建方案落库但不付款、不授予权限。

准备事务强制步骤顺序、对象和金额，禁止跳步、改额或使用新步骤编号重做计划内付款。成功后再处理后一步；拒绝、失败、过期或未知结果停止后续。已生效的独立业务不因后续失败自动回滚。

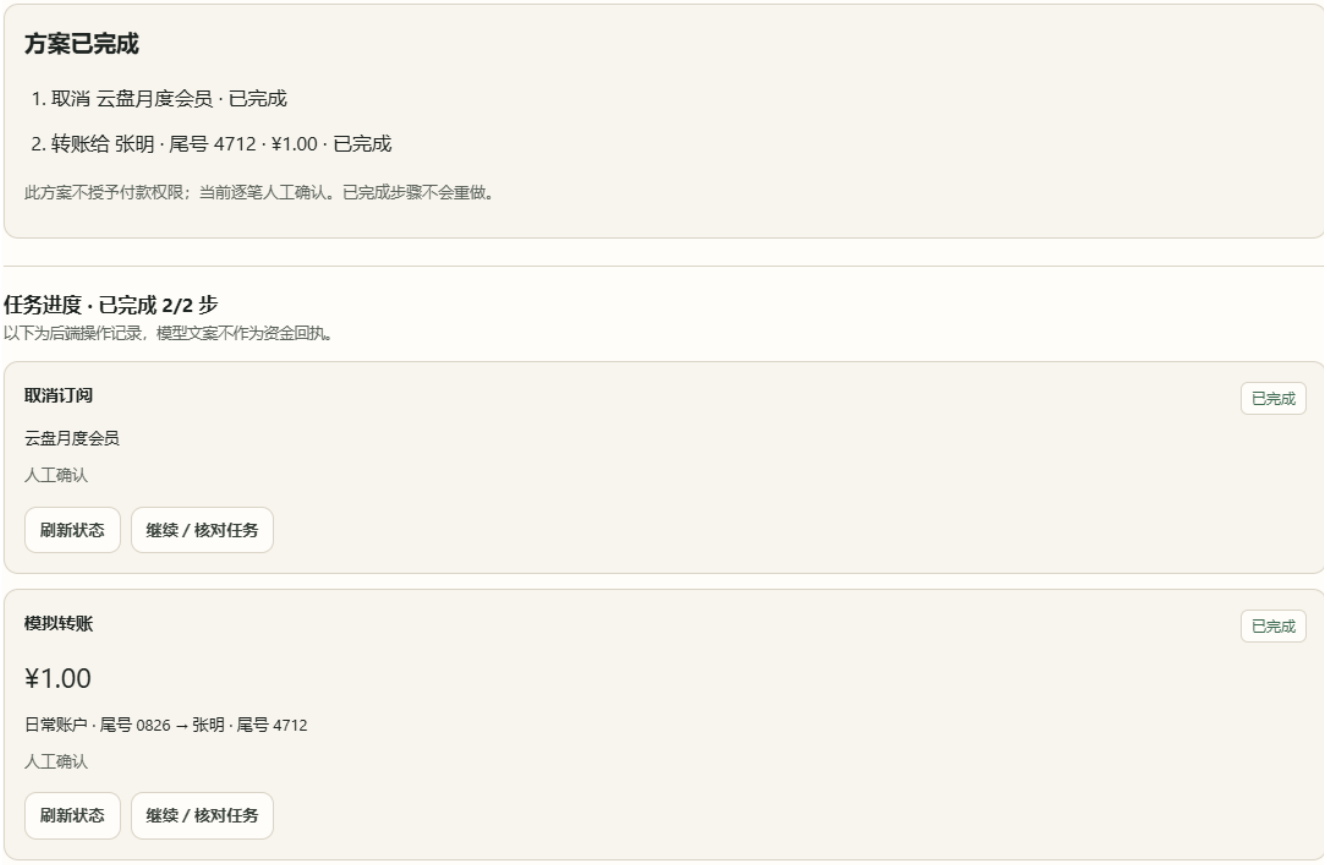


图5 独立虚构数据库中完成"取消订阅 → 转账1元"，实际执行器回执2/2步。Agent为脚本化演示，不访问供应商。 局部放大排版，原始完整PNG随素材包附送。

刷新恢复实际进度，不因刷新调用模型或再次付款。未来少支出不是本次到账，仍需现有可用余额足额。依据：banking/workflows.py；tests/test_transfer_workflows.py。

09 / 安全设计与本地运行

权限、资金和模型三层边界

身份由服务端会话解析，模型不能替换owner、批准动作或创建授权。登录仅允许本人查询与意图准备；执行依赖独立批准或显式预授权。参数校验、跨用户归属、幂等与授权额度由应用和执行器强制检查，不依赖提示词自律。

安全控制	实现要点
认证与请求边界	Argon2id；服务端会话；HttpOnly/SameSite Cookie；CSRF/Origin/Host；登录限流
资金与额度	单笔上限、累计支出和预占、最低保留余额、授权期限和对象范围；未知结果保守暂停
输入与展示	严格Pydantic字段、32KB请求体边界、前端安全Markdown子集及文本转义
第三方数据	模型模式发送提问、历史和本人模拟财务数据；密码、Cookie和CSRF不进入模型消息
追踪	终端正文默认开启，可关闭；LangSmith云追踪默认关闭，正文另有开关；追踪不是可靠账本

部署与运维

单机、单进程SQLite；入口仅监听显式本机回环HTTP。新库初始化，旧库通过独立升级命令先备份再增表，启动不自动迁移。依赖按requirements-dev.lock约束安装，前端无需Node构建。

明确的适用限制

本地测试密码允许1-128字符；该政策及回环HTTP例外不能直接用于公网。未实现高可用、真实银行对接、监管合规认证或独立渗透审计。详细风险与上线条件见安全自评报告。

10 / 验证结果、限制与复现

证据	结果	适用范围
自动化回归	222 passed，31.83秒；原日志保留	包含参数化用例；模型HTTP用替身，不是222条真实模型任务
静态检查	Ruff lint通过；36个Python文件格式通过	针对当前项目源码与测试
界面演示	14张真实页面截图，完成2/2步	合成数据库、脚本化Agent；移动图仅浏览器视口
历史真实模型	36条固定样本中35条结构检查通过	1条输出预算耗尽被安全拦截；不是97.2%业务成功率
新功能模型语义	列示人工用例已审核通过（负责人确认）	人工结论来源为负责人反馈；不新增模型统计成功率

复现入口

部署指南提供新目录安装、配置、用户创建、健康检查、端口冲突定位与旧库升级说明。测试用例文档列出自动化节点、人工步骤与验收预期。源码包包含实际tests/与evals/，归档哈希用于核对工作树快照。

本次将源码ZIP隔离解压，使用本机已有依赖复测：222 passed in 40.14s。归档代码可运行；这不是全新机器或全新依赖安装验收。原日志为source-archive-pytest.txt。

尚未实现或未完成

未接入真实支付，不支持定时转账、AA收款、手机号查人、后台无人登录代办、生日资金锁定、外部预订、通用任意规划器、RAG和多Agent。理财和卡片只读。尚需最终团队署名、队友审查、冻结代码与干净环境重新安装验证。

文件依据与配套资料

源码：app.py、agent.py、context.py、agent_operations.py、banking/service.py、reports.py、subscriptions.py、contacts.py、workflows.py。
验证：tests/；evals/banking-agent.json；docs/agent-evaluation-results.md。
材料：README.md、deployment-guide.md、test-cases.md、security-self-assessment.pdf、evidence/source-manifest.json。